

Data leak worksheet

Incident summary: A sales manager shared access to a folder of internal-only documents with their team during a meeting. The folder contained files associated with a new product that has not been publicly announced. It also included customer analytics and promotional materials. After the meeting, the manager did not revoke access to the internal folder, but warned the team to wait for approval before sharing the promotional materials with others.

During a video call with a business partner, a member of the sales team forgot the warning from their manager. The sales representative intended to share a link to the promotional materials so that the business partner could circulate the materials to their customers. However, the sales representative accidentally shared a link to the internal folder instead. Later, the business partner posted the link on their company's social media page assuming that it was the promotional materials.

Control	Least privilege
Issue(s)	<i>What factors contributed to the information leak?</i> Based on this situation, they did not consider defense in depth, and there are no backup layers in case data has been leaked to customers. Right after the meeting, the manager should have revoked the access to the internal folder. Only provide access to limited workers, staff.
Review	<i>What does NIST SP 800-53: AC-6 address?</i> For SP 800-53: AC-6, the first core principle is security control, and then Second is based on discussion which tells how control should be implemented In this category, all user accounts, specific roles to organizations, there has to Be enforced by rules and regulations, for both internal and external. It is essential to Limit the privilege more than what the staff deserves for his role. For control enhancements, you restrict access and only allow for people with

	Specific clearance to do so.
Recommendation(s)	<i>How might the principle of least privilege be improved at the company?</i> In this case, control enhancements using restricting access to sensitive resources based on user role will work, because only limited personnel that truly need to access file or sensitive data can edit, publish, or change its format. Another one is to regularly audit user privileges which is essential on a regular basis for sensitive data that needs to be accessed.
Justification	<i>How might these improvements address the issues?</i> Here, control enhancement with restricting access will reduce the likelihood of another data leak by not all staff members not being able to do anything with data. And only people with additional clearance or permission are more privileged, and better trained than regular workers to access sensitive data. For regular audit user privileges, it's important to check regular diagnosis on sensitive data, and make sure there is no unusual activity in the most unexpected manner, and time.

Security plan snapshot

The NIST Cybersecurity Framework (CSF) uses a hierarchical, tree-like structure to organize information. From left to right, it describes a broad security function, then becomes more specific as it branches out to a category, subcategory, and individual security controls.

Function	Category	Subcategory	Reference(s)
Protect	PR.DS: <i>Data security</i>	PR.DS-5: <i>Protections against data leaks.</i>	NIST SP 800-53: AC-6

In this example, the implemented controls that are used by the manufacturer to protect against data leaks are defined in NIST SP 800-53—a set of guidelines for securing the privacy of information systems.

Note: References are commonly hyperlinked to the guidelines or regulations they relate to. This makes it easy to learn more about how a particular control should be implemented. It's common to find multiple links to different sources in the references columns.

NIST SP 800-53: AC-6

NIST developed SP 800-53 to provide businesses with a customizable information privacy plan. It's a comprehensive resource that describes a wide range of control categories. Each control provides a few key pieces of information:

- **Control:** A definition of the security control.
- **Discussion:** A description of how the control should be implemented.
- **Control enhancements:** A list of suggestions to improve the effectiveness of the control.

AC-6	Least Privilege
	Control: Only the minimal access and authorization required to complete a task or function should be provided to users.
	Discussion: Processes, user accounts, and roles should be enforced as necessary to achieve least privilege. The intention is to prevent a user from operating at privilege levels higher than what is necessary to accomplish business objectives.
	Control enhancements: ● Restrict access to sensitive resources based on user role. ● Automatically revoke access to information after a period of time. ● Keep activity logs of provisioned user accounts. ● Regularly audit user privileges.

Note: In the category of access controls, SP 800-53 lists least privilege sixth, i.e. AC-6.